



FUNDAMENTALS OF INFORMATION SECURITY

SESSION 11

COURSE CODE:

CYBE 6123

LECTURER: **NGUEMETA NATHANIEL**



Auditing, Testing, and Monitoring

Objective of the session

- What security auditing and analysis are
- How to define an audit plan
- What auditing benchmarks are
- How to collect audit data
- Which post-audit activities you need to perform
- How to perform security monitoring
- Which types of log information you should capture
- How to verify security controls
- How to monitor and test the security systems

Security Auditing and Analysis

- Are security policies sound and appropriate for the business or activity?
- Are there controls supporting the policies?
- Is there effective implementation and upkeep of controls?

Ensure Security Controls Address Risk

- **Monitor**—Review and measure all controls to capture actions and changes to any environment component
- **Audit**—Review the logs and overall environment to provide independent analysis of how well the security policy and controls work
- **Improve**—Include proposals to improve the security program and controls in the audit results.
- **Secure**—Ensure that new and existing controls work together to protect the intended level of security

Security Assurance

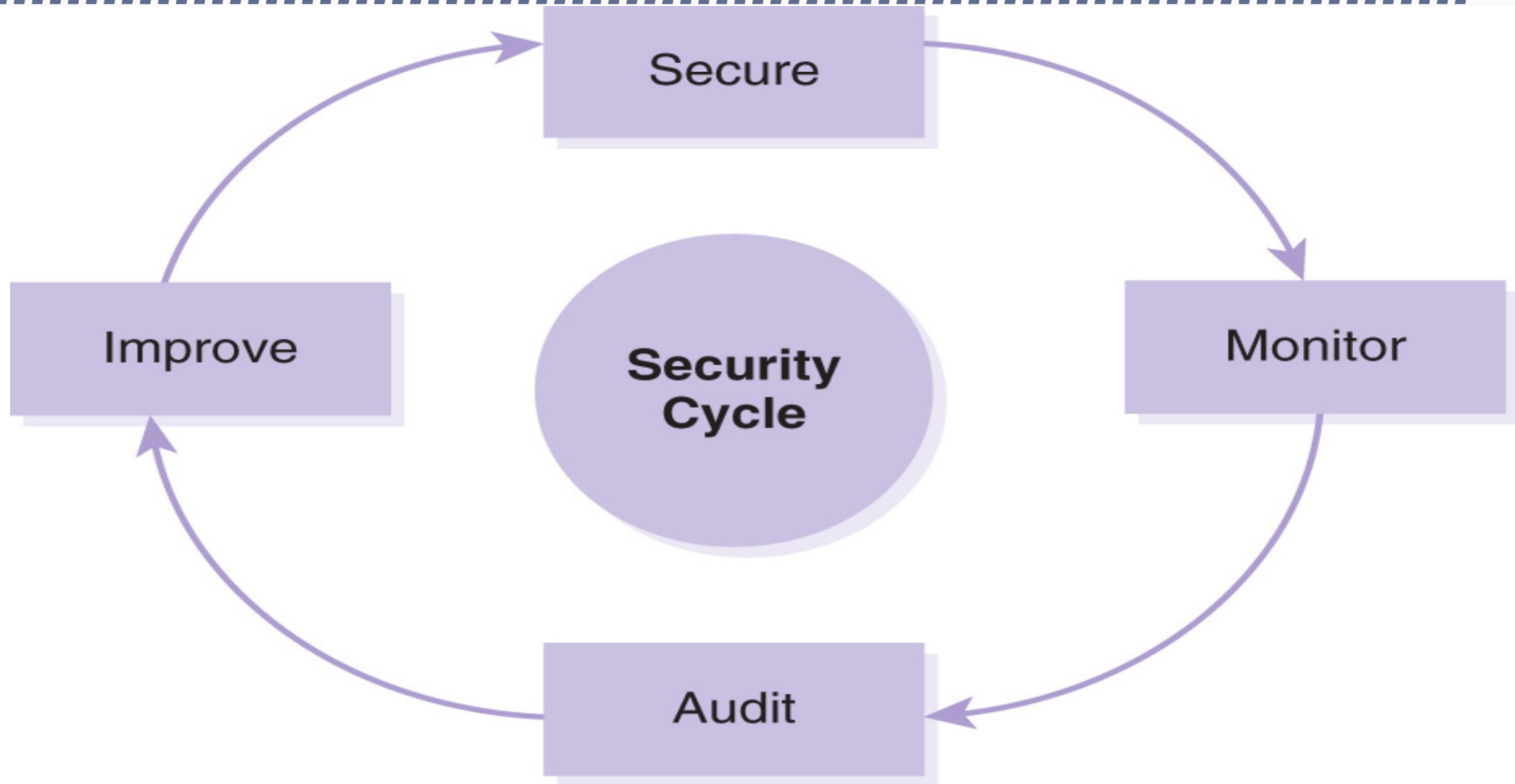


FIGURE 10-1 The security review cycle.

Permission Levels



- **Promiscuous**—Everything is allowed. This permission level is used by many home users, but it makes it easier for attackers to succeed.
- **Permissive**—Anything not specifically prohibited is okay.
- **Prudent**—A reasonable list of things is permitted, and all others are prohibited. This permission level is suitable for most businesses.
- **Paranoid**—Very few things are permitted, and all others are prohibited and carefully monitored.

Purpose of Audits



- **Appropriate security level**—Is the level of the security control suitable for the risk it addresses?
- **Correctly installed**—Is the security control in the right place and working well?
- **Effectiveness of purpose**—Is the security control effective in addressing the risk it was designed to address?

Defining the Audit Plan

- Define the objectives of the audit
- Determine which systems or business processes to review (Scope)
- Define which areas of assurance to check
- Identify the personnel who will participate in the audit

Defining the Scope of the Plan

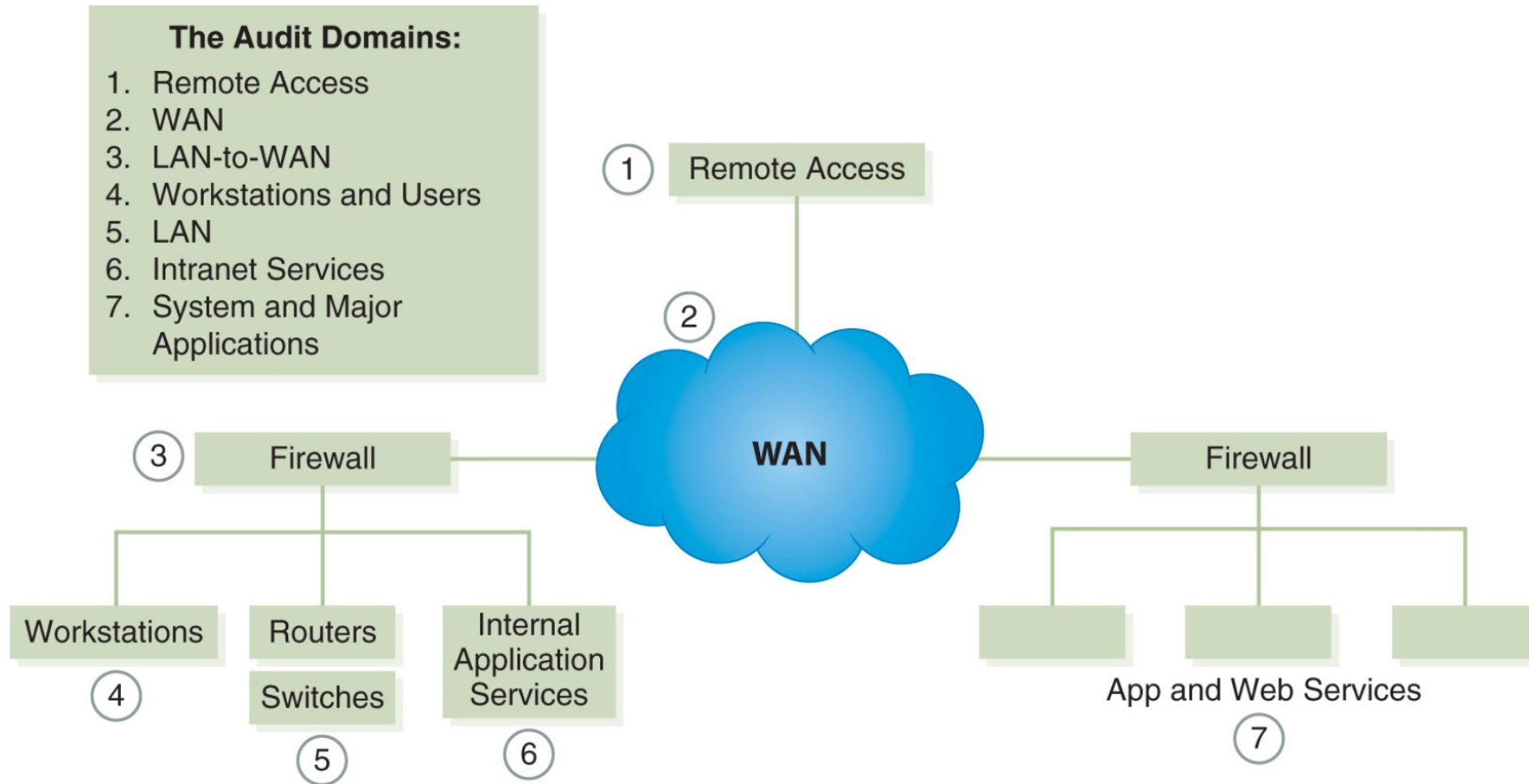


FIGURE 10-2 Audit scope and the seven domains of the IT infrastructure.

Performing the Audit



- Survey the site(s)
- Review documentation
- Review risk analysis output
- Review server, device, and application logs
- Review incident logs
- Review results of penetration tests

Audit Benchmarks



- ISO Standards
- PCI DSS
- NIST
- ISF SOGP
- Organizational Policies

Audit Data Collection Methods

- Questionnaires
- Interviews
- Observation
- Checklists
- Reviewing documentation
- Reviewing configurations
- Reviewing policy
- Performing security testing

Generation of Audit Report

- Findings—The findings are often listed by level of compliance to the standard benchmark
- Recommendations—Auditors recommend how to fix the risks they have found
 - Timeline for implementation—Change recommendations should not be open ended. Level of risk—The audit should make clear the level of risk the organization faces from each finding.
 - Management response—Auditors should give management an opportunity to respond
- Follow-up—When necessary, auditors should schedule a follow-up audit

Closing the Audit



- Exit Interview
- Presentation of Findings
- Collection of feedback (Where necessary)
- Recommendation for certification (where necessary)

Security Monitoring

- Baselines
- Alarms, alerts, and trends
- Closed-circuit TV
- Systems that spot irregular behavior
 - Host-based IDS
 - System or file integrity monitoring
 - Data loss prevention (DLP)

Logging



- **Event logs**—General operating system and application software events
- **Access logs**—Access requests to resources
- **Security logs**—Security-related events
- **Audit logs**—Defined events that provide additional input to audit activities

Logging

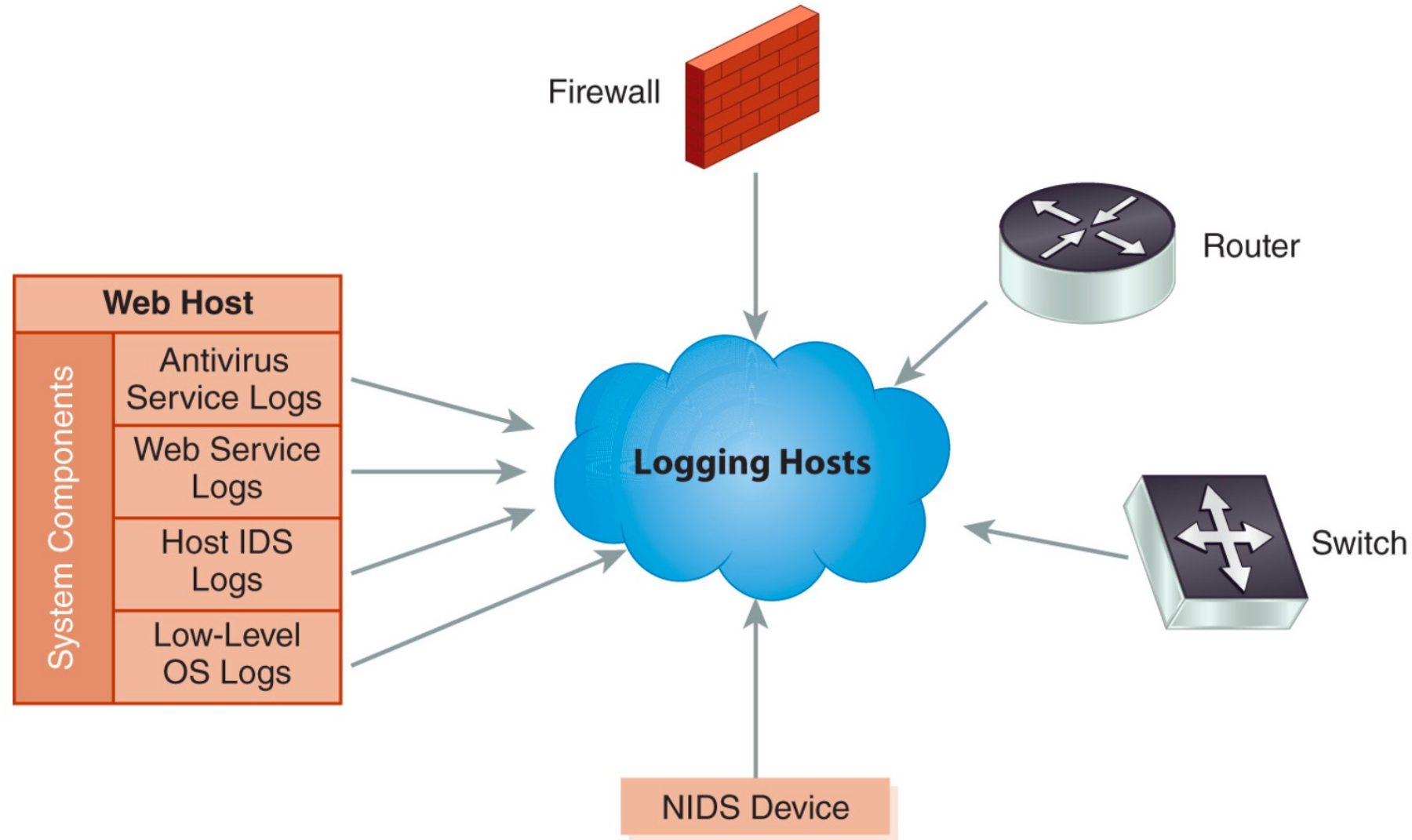


FIGURE 10-3 Types of log information.

Log Analysis and Incident response

- Security information and event management (SIEM) system
 - Logs co-relation
 - Incident identification and classification
 - Solution enumeration
- Security orchestration, automation, and response (SOAR) system
 - Logs co-relation
 - Incident identification and classification
 - Solution enumeration and structural response

Recommended Security Controls

- Intrusion Detection/Prevention System (NIDS, HIDS/HIPS)
- Layered Defense: Network Access Control
- Host Isolation (demilitarized zone (DMZ))
- System Configuration Hardening
- Set a Baseline Configuration
- Disable or Remove Unnecessary Services
- Review Endpoint Protection Programs

Layered Network

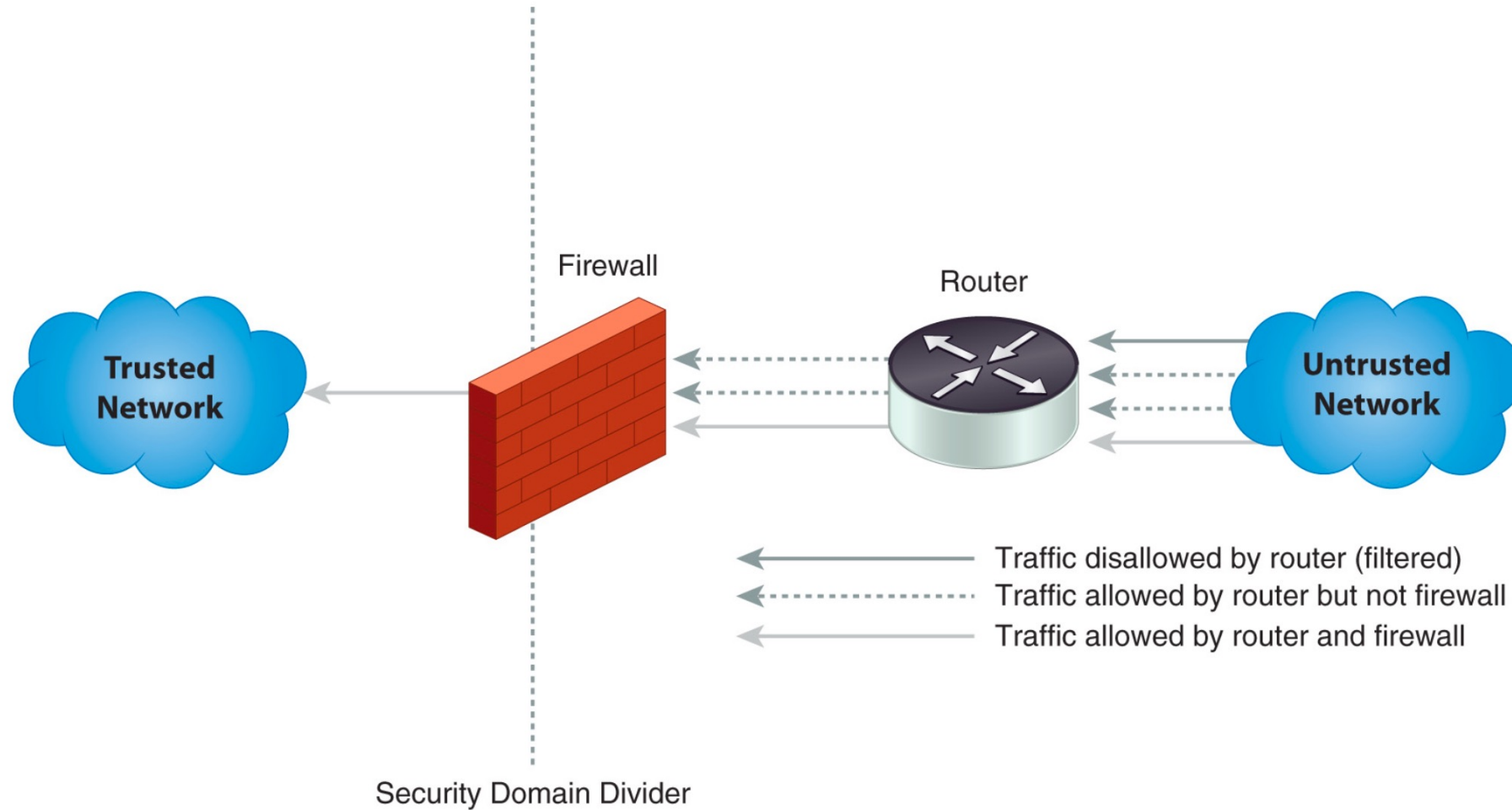


FIGURE 10-6 Layered network devices trying to prevent an attack on the internal protected network.

Demilitarized Zone (DMZ)

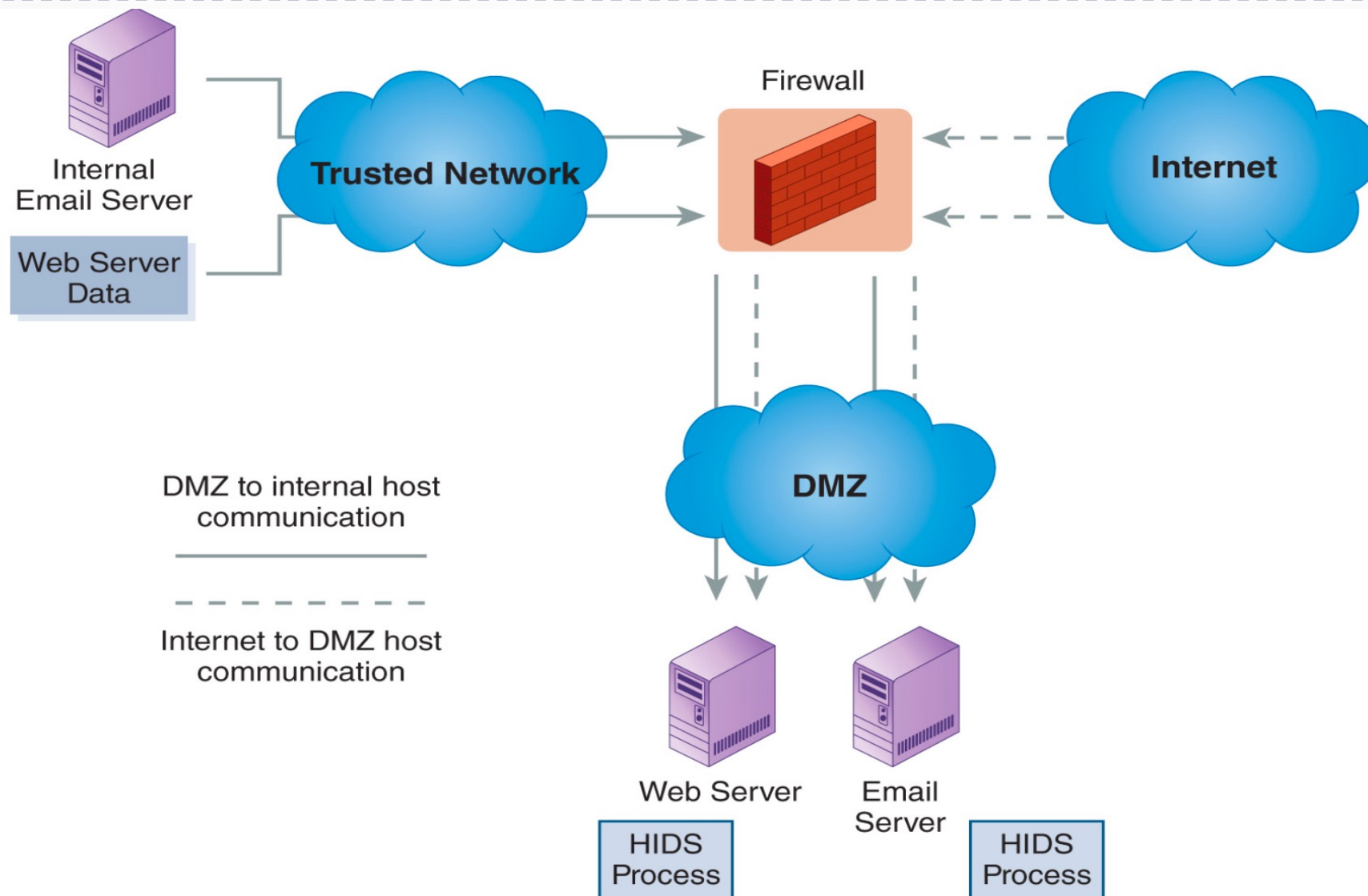


FIGURE 10-8 Host isolation and the DMZ.

Testing Security Systems

- The goals of vulnerability testing include:
 - Identifying vulnerability (passively)
 - Documenting lack of security control or misconfiguration
 - Examining vulnerabilities related to credentialed and noncredentialed users
- The goals of penetration testing include:
 - Identifying threats
 - Bypassing controls
 - Exploiting vulnerabilities

Testing Road Map



- **Reconnaissance**
- **Network mapping**—This phase uses tools to determine the layout and services running on the organization's systems and networks.
- **Vulnerability testing**—Vulnerability testing involves finding all the weaknesses in a system and determining which places may be attack points.
- **Penetration testing**—In this phase, you try to exploit a weakness in the system and prove that an attacker could successfully penetrate it.
- **Mitigation activities**

Testing Road Map

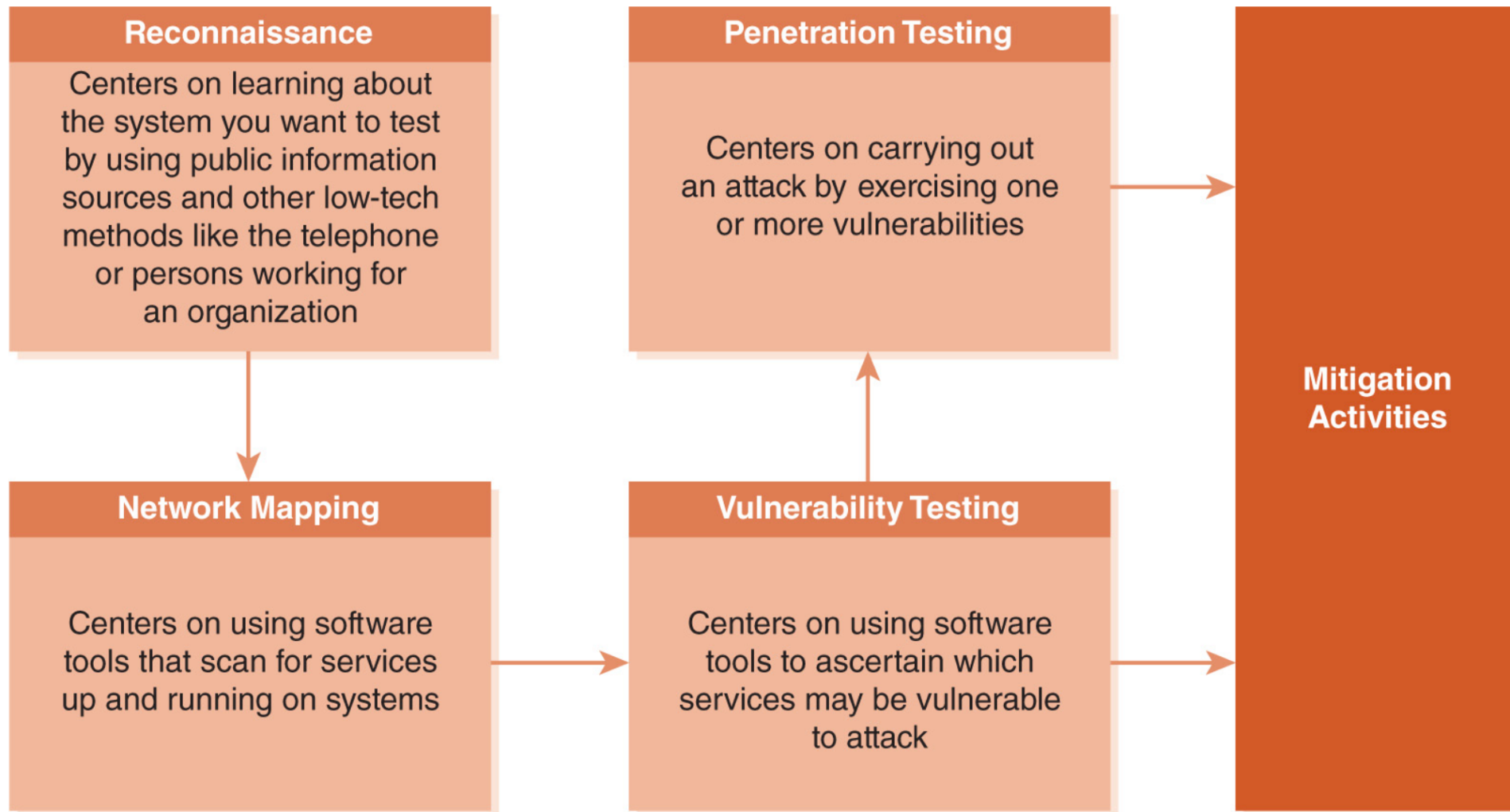


FIGURE 10-10 Security testing might take several paths.

Assignment

- List and describe 5 Important steps of Audit Project
- Complete and submit assessment.



Thank You